Threat Modeling Playbook

Security architecture · TMP-01 · Version 2.0 · Effective 1 June 2026

> Fictional sample document for testing a domain-specialist RAG. Required controls are cited as, for example, "TM-04".

1. When to threat model

Every new service, every new external integration and every change that moves data across a trust boundary needs a threat model before the design review. Threat models are updated at least once a year.

2. Method: STRIDE per element

Category	Question to ask	Typical control
Spoofing	Can someone pretend to be a user, service or partner?	Strong authentication, mTLS, signed requests
Tampering	Can data be changed in transit or at rest?	TLS, signatures, integrity checks, write-once logs
Repudiation	Can someone deny an action?	Tamper-evident audit logs with user and time
Information disclosure	Can data leak to the wrong party?	Encryption, access control, data minimisation
Denial of service	Can the service be made unavailable?	Rate limits, quotas, autoscaling, WAF
Elevation of privilege	Can someone gain rights they should not have?	Least privilege, object-level authorisation

3. Severity

Severity = likelihood × impact, each scored 1 to 3. Score 9 is **Critical**, 6 is **High**, 3 or 4 is **Medium**, 1 or 2 is **Low**. Any threat that can expose payment card data, authentication secrets or more than 10,000 customer records is at least High regardless of likelihood.

Critical threats block launch. High threats need a mitigation before launch or a risk acceptance signed by the CISO, valid for 90 days.

4. Required controls

Control	Requirement
`TM-01`	All public entry points sit behind the WAF and API gateway, with rate limiting per client.

TM-02	Service-to-service calls inside the cluster use mTLS with workload identities; no shared static credentials.
TM-03	Inbound webhooks and partner callbacks are verified with HMAC signatures and timestamps (replay window 5 minutes).
TM-04	Data stores holding personal or payment data are encrypted at rest with KMS-managed keys, and access is limited to the owning service's identity.
TM-05	Each service's cloud role follows least privilege; wildcard permissions such as `s3:*` or `*:*` are forbidden.
TM-06	Outbound calls to the internet go through the egress proxy with a host allow-list.
TM-07	Queues and event buses require authenticated producers and consumers; messages carrying personal data are encrypted.
TM-08	Admin interfaces are reachable only through the corporate VPN or zero-trust access proxy with MFA.
TM-09	Every data store has backups in a second region and a tested restore (see RPO and RTO in the operations runbook).
TM-10	Security-relevant actions are written to an append-only audit log retained for 1 year.
TM-11	LLM components treat retrieved documents, tool results and user uploads as untrusted; model output is never executed, and tools run with the calling user's permissions.
TM-12	Third-party SDKs and models are pinned, scanned, and loaded from the internal registry only.